

1/ Foot Printing Tools - Competitive Intellegents

Foot Printing is the process of collecting information about a target organization. In passive foot printing information is gathered from publicly available sources without directly ~~to~~ interacting with the target company's servers.

Following tools can be used:

- 1/ WHOIS:- Used to obtain domain registration details such as register name, registration expiry dates, name servers and publicly available registration information it helps understand the company's domain infrastructure.
- 2/ The Harvester:- An OSINT tool used to find infrastructure indexed, employee mail addresses, hostnames and related information it can also reveal the Organisation email naming pattern.
- 3/ Wapplyzer:- These tools identify the technologies used by a public website, such as C++, frameworks, Javascript libraries, analytics services hosting and technologies.
- 4/ Crt.sh:- Searches Certificate transparency logs and can reveal publicly exposed subdomains such as mail.ex.com.

Completive intelligent:- These tools help understand on organizations public digital presence, technologies, employees and infrastructure. The collected infrastructure can also be used to compare the organization.

2) DNS Zone Transfer

A DNS zone transfer is used to copy DNS records from one DNS server to the another. A full zone transfers uses the AXFR mechanism. During an authorized penetration last the analyst can check whether a DNS server is incorrectly allowing an-authorized zone transfer.

First test zone transfer against on authorized target:-

`dig ns example.com`

Then test the zone transfer against an authorized target

`dig AXFR example.com`

`dns.example.com.`

if the DNS is properly configured, the request should normally be refused. If the transfer succeeds.

Important records:

A record:- Identify hostnames and their IP address

My record:- Identify organizational mail servers.

NS records: Identify authoritative name servers

Name records: Reveal aliases and related services

TXT records:- may reveal SPF, verification and other public configuration information.

For example:- The retrieved records might reveal DNS-visible host such as mail.exm.com

Counter measures:- Zone transfers should be restricted so that authorized secondary DNS servers can perform AXFR/IXFR requests.

3) Social Engineering attack and counter measures.

The given scenario is phishing attack which is a common type of social engineering attack. The attacker pretends to be the organization IT department and creates this credentials through provided link.

Employees should follow these counter measures

* Do not immediately click the link:- Instead

The organizations website or posted through a known trusted method.

2, Verify the sender:- Check the complete sender email address and domain rather than trusting only the displayed name.

3, Check Suspicious Links:- Confirm the sender mail should verify where you link heads, before opening it and avoid unknown or mismatched domains,

4, Contact the Id department:- Inform the request testing on official phone number help desk system or trusted communication channel.

5, Never share Passwords or OTP:- Employees should never provide passwords, OTPs or relevany codes in response to unsolicited emails.

6, Use multi-factor authentication:- MFA provides an additional authentication layer reducing the impact of stolen password.

7, Report Phishing:- Suspicious messages should be reported to the organization security or IT team so that they can investigate and warn other employees

8, Security awareness training:- Regular training helps employees identify suspicious emails, fake login pages, Imposantion and urgency based manipulation.